

Security+ 4.1 · Hardening Targets

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 4.1 — Hardening Targets (10:11)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Alvos: wireless (WPA2/3-Enterprise); mobile (MDM, anti-jailbreak); servers (fechar porta, remover serviço); workstations; IoT (segmentar!); ICS/OT (air gap/DMZ); cloud (IAM+SG).

Highlights que a prova cobra

- IoT (câmera, sensor): a superfície MAIS esquecida — segmentar
- ICS/OT (fábrica): air gap ou DMZ industrial

Dicas de prova & Cenários Típicos

- 'segmenting IoT devices'=security control for IoT

Cenário clássico de exame: 'câmeras IP da empresa estão na mesma VLAN que as estações de trabalho'=risky — segmentar IoT.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 4.1 — Hardening Targets)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Sub-rede isolada que expõe servidores públicos (web/email) protegendo a rede interna é a:

- A)** VLAN de voz
- B)** DMZ (screened subnet)
- C)** VPN
- D)** Intranet

2. Isolar FISICAMENTE um sistema crítico da rede (sem nenhuma conexão):

- A)** Air gap
- B)** VLAN
- C)** VPN
- D)** NAT

3. Cenário corporativo (Hardening Targets): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: 'IoT (câmera, sensor): a superfície MAIS esquecida — segmentar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: IoT (câmera, sensor): a superfície MAIS esquecida — segmentar...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Hardening Targets): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: 'ICS/OT (fábrica): air gap ou DMZ industrial'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: ICS/OT (fábrica): air gap ou DMZ industrial...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Hardening Targets): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: 'segmenting IoT devices'=security control for IoT'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'segmenting IoT devices'=security control for IoT...

6. Cenário corporativo (Hardening Targets): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: 'câmeras IP da empresa estão na mesma VLAN que as estações de trabalho'=risky — segmentar IoT.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'câmeras IP da empresa estão na mesma VLAN que as estações de trabalho'=ris...

7. Cenário corporativo (Hardening Targets): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: 'IoT (câmera, sensor): a superfície MAIS esquecida — segmentar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: IoT (câmera, sensor): a superfície MAIS esquecida — segmentar...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Hardening Targets): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: 'ICS/OT (fábrica): air gap ou DMZ industrial'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: ICS/OT (fábrica): air gap ou DMZ industrial...

9. Cenário corporativo (Hardening Targets): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: "segmenting IoT devices'=security control for IoT'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'segmenting IoT devices'=security control for IoT...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Hardening Targets): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.1), um analista avalia o seguinte requisito técnico: "câmeras IP da empresa estão na mesma VLAN que as estações de trabalho'=risky — segmentar IoT.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'câmeras IP da empresa estão na mesma VLAN que as estações de trabalho'=ris...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — DMZ (screened subnet).

✓ **Por que está certa:** A alternativa correta é 'DMZ (screened subnet)'. Uma DMZ (Zona Desmilitarizada), também chamada de sub-rede filtrada (screened subnet), é um segmento de rede isolado que fica entre a rede interna confiável e a rede externa não confiável (como a Internet). Ela hospeda servidores públicos, como web, e-mail, DNS e FTP, que precisam ser acessíveis externamente. O objetivo é que, se um desses servidores for comprometido, o atacante não tenha acesso direto à rede interna, pois há firewalls controlando o tráfego entre a DMZ e a rede interna. O CompTIA Security+ SY0-701, no domínio de Arquitetura e Design (2.2), descreve a DMZ como uma zona de segurança para expor serviços públicos de forma controlada. A questão descreve exatamente essa função: sub-rede isolada que expõe servidores públicos protegendo a rede interna.

✗ **Por que as outras estão erradas:**

- *VLAN de voz*: VLAN de voz é uma rede local virtual dedicada a tráfego de VoIP (voz sobre IP), separando-o dos dados para garantir qualidade de serviço (QoS) e segurança. Ela não é projetada para expor servidores públicos à Internet; pelo contrário, isola o tráfego de voz. Não oferece o isolamento entre rede interna e externa que uma DMZ proporciona. Portanto, não atende ao requisito de proteger a rede interna enquanto expõe serviços públicos.
- *VPN*: VPN (Virtual Private Network) é uma tecnologia que cria um túnel criptografado para transmitir dados de forma segura através de redes não confiáveis, permitindo acesso remoto ou interconexão de filiais. Embora melhore a segurança da comunicação, não é uma sub-rede isolada para hospedar servidores públicos. Uma VPN pode ser usada para acessar a DMZ, mas não substitui a DMZ. A questão pede uma zona de rede que exponha servidores públicos, o que não é a função primária de uma VPN.
- *Intranet*: Intranet é uma rede privada interna que utiliza tecnologias da Internet (como HTTP, FTP) para compartilhar informações dentro de uma organização. Ela é acessível apenas por usuários autorizados e não é exposta ao público externo. Portanto, não serve para hospedar servidores públicos que precisam ser acessados pela Internet. A intranet é o oposto de uma DMZ nesse aspecto: é interna e restrita, não uma zona de exposição controlada.

2) A — Air gap.

✓ **Por que está certa:** Air gap (ou isolamento físico) é a prática de separar fisicamente um sistema crítico de qualquer rede, incluindo Internet, LAN e WAN, de modo que não haja conexão física ou lógica. Isso impede ataques remotos e exfiltração de dados por rede. É usado em ambientes de alta segurança, como sistemas de controle industrial (ICS/SCADA), redes militares e sistemas de votação. Conforme o objetivo SY0-701 3.3 (arquitetura de segurança) e 4.1 (controles de segurança), air gap é a medida mais forte de isolamento. A questão descreve exatamente isolar fisicamente um sistema crítico da rede sem nenhuma conexão, que é a definição de air gap.

✗ **Por que as outras estão erradas:**

- *VLAN*: VLAN (Virtual Local Area Network) é uma segmentação lógica de uma rede física, criada em switches, que permite separar domínios de broadcast e aplicar políticas de segurança. Embora melhore o isolamento lógico, não é um isolamento físico; dispositivos em VLANs diferentes ainda compartilham a mesma infraestrutura física e podem ser interconectados por roteamento ou configuração incorreta. A questão exige isolamento FÍSICO sem nenhuma conexão, o que VLAN não proporciona, pois mantém conectividade lógica e física subjacente.
- *VPN*: VPN (Virtual Private Network) é um túnel criptografado que permite comunicação segura através de redes não confiáveis, como a Internet. Ela fornece confidencialidade e integridade, mas

não isola fisicamente o sistema; pelo contrário, conecta o sistema a uma rede remota de forma segura. A questão pede isolamento físico sem nenhuma conexão, o que é incompatível com VPN, que pressupõe conectividade de rede.

- **NAT:** NAT (Network Address Translation) é uma técnica que traduz endereços IP privados para públicos (e vice-versa), permitindo que vários dispositivos compartilhem um único endereço IP público. Ele oculta a topologia interna, mas não isola fisicamente; o sistema continua conectado à rede. A questão exige isolamento físico sem conexão, o que NAT não oferece, pois é um mecanismo de roteamento que mantém a conectividade.

3) C — Implementar a solução correspondente: IoT (câmera, sensor): a superfície MAIS esquecida — segmentar....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Hardening Targets): IoT (câmera, sensor): a superfície MAIS esquecida — segmentar.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) C — Implementar a solução correspondente: ICS/OT (fábrica): air gap ou DMZ industrial....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Hardening Targets): ICS/OT (fábrica): air gap ou DMZ industrial.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) D — Implementar a solução correspondente: 'segmenting IoT devices'=security control for IoT....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Hardening Targets): 'segmenting IoT devices'=security control for IoT.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são

controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: 'câmeras IP da empresa estão na mesma VLAN que as estações de trabalho'=ris....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Hardening Targets): 'câmeras IP da empresa estão na mesma VLAN que as estações de trabalho'=risky — segmentar IoT..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) A — Implementar a solução correspondente: IoT (câmera, sensor): a superfície MAIS esquecida — segmentar....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Hardening Targets): IoT (câmera, sensor): a superfície MAIS esquecida — segmentar.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) D — Implementar a solução correspondente: ICS/OT (fábrica): air gap ou DMZ industrial....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Hardening Targets): ICS/OT (fábrica): air gap ou DMZ industrial.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam

ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) B — Implementar a solução correspondente: 'segmenting IoT devices'=security control for IoT....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Hardening Targets): 'segmenting IoT devices'=security control for IoT.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) A — Implementar a solução correspondente: 'câmeras IP da empresa estão na mesma VLAN que as estações de trabalho'=ris....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.1 (Hardening Targets): 'câmeras IP da empresa estão na mesma VLAN que as estações de trabalho'=risky — segmentar IoT..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.